

Secure Logging and Auditing Protocols

Author: InfoSec Assurance Team	Target Audience: Full Stack & DevOps Engineering	Compliance Target: SOC 2 Type II, PCI-DSS Log Security
---------------------------------------	---	---

1.0 Purpose & Scope

Application logs are designed for operational diagnostics, but they frequently become vector targets for data exfiltration when developers carelessly dump raw objects. This policy mandates strict scrubbing procedures to keep confidential information out of systemic application traces.

2.0 Sanitization Standards & Logging Restrictions

Section 2.1 Elimination of Plain-Text Financial Identifiers

System diagnostic logs must never capture or write un-scrubbed financial variables. This includes explicit restrictions against writing raw primary account numbers (PAN), CVVs, authorization tokens, security passwords, pin strings, or complete customer identification packages into application trace logs.

Section 2.3 Logging Framework Restrictions

Engineers are prohibited from using raw serialization techniques (e.g., Serilog's direct @ destructuring symbol on top-level input data models) when the target object contains sensitive metadata. Instead, variables must be explicitly selected and routed through the centralized, corporate-approved `MaskingLoggerProvider` to ensure automatic character masking (e.g., tokenizing card values down to the final four digits).

COMPLIANCE ALERT: Allowing raw financial parameters to leak into logs replicates sensitive variables across downstream log aggregators and diagnostic dashboards. This results in immediate failures during annual SOC 2 Type II and PCI audits, creating costly cleanup liabilities.